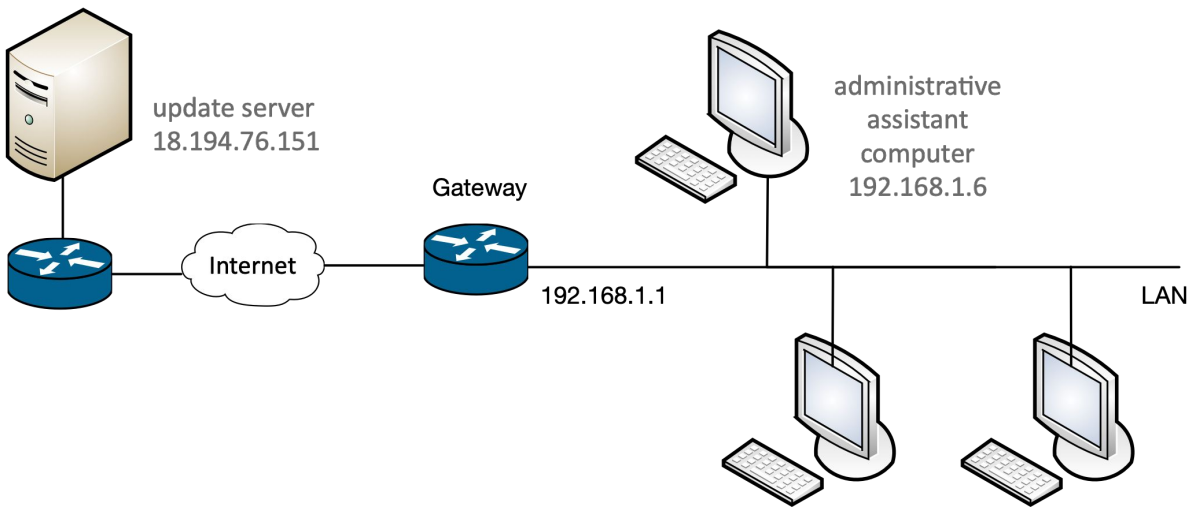
Exercises
Network Protocols Attacks

Computer Security

Question

As part of your job as a security analyst, one of your clients discovers that their network is compromised. In particular, from an early analysis, they have ground to suspect that the start of the compromise was a network attack against the computer of the administrative assistant.

Consider the following (simplified) schema of the company network.



1. Your client managed to capture the network traffic on the administrative assistant's computer (IP address *192.168.1.6* and MAC address *dc:a9:04:7a:ce:29*) when the attack was taking place. During the traffic capture, the computer was automatically updating a well-known accounting software from the software vendor's web server (IP address *18.194.76.151* and MAC address *dc:a6:03:01:02:fe*). You also know that the IP address of the LAN interface of the company's network gateway is *192.168.1.1*, and its MAC address is *b6:28:97:ca:b7:48*.

1 dc:a9:04:7a:ce:29 → ff:ff:ff:ff:ff:ff **ARP** *Who has 192.168.1.1? Tell 192.168.1.6*
2 38:60:77:b9:79:98 → dc:a9:04:7a:ce:29 **ARP** *192.168.1.1 is at 38:60:77:b9:79:98*
3 b6:28:97:ca:b7:48 → dc:a9:04:7a:ce:29 **ARP** *192.168.1.1 is at b6:28:97:ca:b7:48*
4 192.168.1.6 (dc:a9:04:7a:ce:29) → 18.194.76.151 (38:60:77:b9:79:98) **TCP** *SYN*
5 18.194.76.151 (38:60:77:b9:79:98) → 192.168.1.6 (dc:a9:04:7a:ce:29) **TCP** *SYN, ACK*
6 38:60:77:b9:79:98 → dc:a9:04:7a:ce:29 **ARP** *192.168.1.1 is at 38:60:77:b9:79:98*
7 192.168.1.6 (dc:a9:04:7a:ce:29) → 18.194.76.151 (38:60:77:b9:79:98) **TCP** *ACK*
8 38:60:77:b9:79:98 → dc:a9:04:7a:ce:29 **ARP** *192.168.1.1 is at 38:60:77:b9:79:98*
9 192.168.1.6 (dc:a9:04:7a:ce:29) → 18.194.76.151 (38:60:77:b9:79:98) **TCP** *HTTP GET /downloads/software-update.exe*
10 18.194.76.151 (38:60:77:b9:79:98) → 192.168.1.6 (dc:a9:04:7a:ce:29) **TCP** *HTTP 200 OK ...*

(assume that the traffic is captured directly from the network interface card of the employee's PC)

1.1 [2 points]. Describe the attack going on in the network, specifying the name and providing a short explanation of how the attack works *in general*.

1.1 [2 points]. Describe the attack going on in the network, specifying the name and providing a short explanation of how the attack works *in general*.

ARP spoofing, see slide.

1.2 [1 point]. What is the goal of the attack, <u>in this specific case</u>? Motivate your answer.

1.2 [1 point]. What is the goal of the attack, <u>in this specific case</u>? Motivate your answer.

Sniffing or manipulation of the traffic to\from the compromised machine. We can rule out DOS as the traffic passes (there are responses from the server).

Likely, given the scenario (malware infection), the attack is targeted at tampering with the data in transit rather than (or in addition to) sniffing.

1.3 [1 point]. Can you tell the IP address of the attacker? And the MAC address?

1.3 [1 point]. Can you tell the IP address of the attacker? And the MAC address?

IP address: no

MAC address: the attacker is using 38:60:77:b9:79:98, but it could very well be a spoofed address.

1.4 [1 point]. Given only the above packet capture, can you tell whether the attacker is located (i.e., on the LAN, on the same network of the web server, or on an arbitrary Internet-connected network)? Why?

1.4 [1 point]. Given only the above packet capture, can you tell whether the attacker is located (i.e., on the LAN, on the same network of the web server, or on an arbitrary Internet-connected network)? Why?

The attacker is located on the same network of the target machine, i.e., on the LAN.

Question

Suppose that you are the network security administrator of the network `131.168.0.0/24`, with gateway `131.168.0.1` and DNS servers `131.168.0.100` and `131.168.0.101`. While examining the network activity, you notice a DHCP offer packet coming from IP `131.168.0.10` with gateway set to `131.168.0.5`. Answer the following questions and provide a reason. Answers with no reason will not give any point.

- What kind of attack do you suspect, and how does it work?

- What kind of attack do you suspect, and how does it work?

DHCP poisoning. Someone is trying to trick a client connected to 131.168.0.0/24 into believing that `131.168.0.5` *is the gateway, by sending a crafted DHCP offer before, which comes before the real offer sent out by the real DHCP server.*

- Why such an attack works?

- Why such an attack works?

Because the DHCP protocol does not support authentication, so the client must blindly believe any DHCP offer that it sees, and because an arbitrary client can race (and win) against the real DHCP server.

- Can you tell the IP address of the host where those packets come from?

- Can you tell the IP address of the host where those packets come from?

Not really. 131.168.0.10 is the sender of the DHCP offer, but the address may be spoofed. We could look at the MAC address of the scender, but it could be spoofed as well.

- Can you tell the IP address or network address of the victim?

- Can you tell the IP address or network address of the victim?

From the above information there is little evidence to say that, although the potential victims are those that will receive and accept the spoofed DHCP offers. So, likely, 131.168.0.0/24.

Question

A network analyst is analyzing some traffic captured from a network belonging to Politecnico di Milano. The network is: 131.175.0.0/16. In particular, we suspect that a database server, whose IP address is 131.175.14.12, is victim of an attack. Indeed, observing the network traffic, we notice the following pattern:

131.175.14.12 → 131.175.255.255 [ICMP] Echo (ping) request
(broadcast)

131.175.0.2 → 131.175.14.12 [ICMP] Echo (ping) reply
7a:ce:29 → ff:ff:ff (broadcast) [ARP] Who has 131.175.14.12?
Tell 131.175.0.2
4b:74:28 → 7a:ce:29 [ARP] 131.175.14.12 is at
4b:74:28
131.175.0.3 → 131.175.14.12 [ICMP] Echo (ping) reply
131.175.0.4 → 131.175.14.12 [ICMP] Echo (ping) reply
⋮
131.175.255.251 → 131.175.14.12 [ICMP] Echo (ping) reply
131.175.255.252 → 131.175.14.12 [ICMP] Echo (ping) reply
131.175.255.253 → 131.175.14.12 [ICMP] Echo (ping) reply

1. [2 point] Describe what attack you think is going on, and what is the feature (or lack thereof) of the involved protocol(s) that enable this attack.

1. [2 point] Describe what attack you think is going on, and what is the feature (or lack thereof) of the involved protocol(s) that enable this attack.

PING Smurf - see slides ....

Authentication

2. [2 point] Describe what you think is the **concrete** goal(s) of the attack in this scenario

2. [2 point] Describe what you think is the **concrete** goal(s) of the attack in this scenario

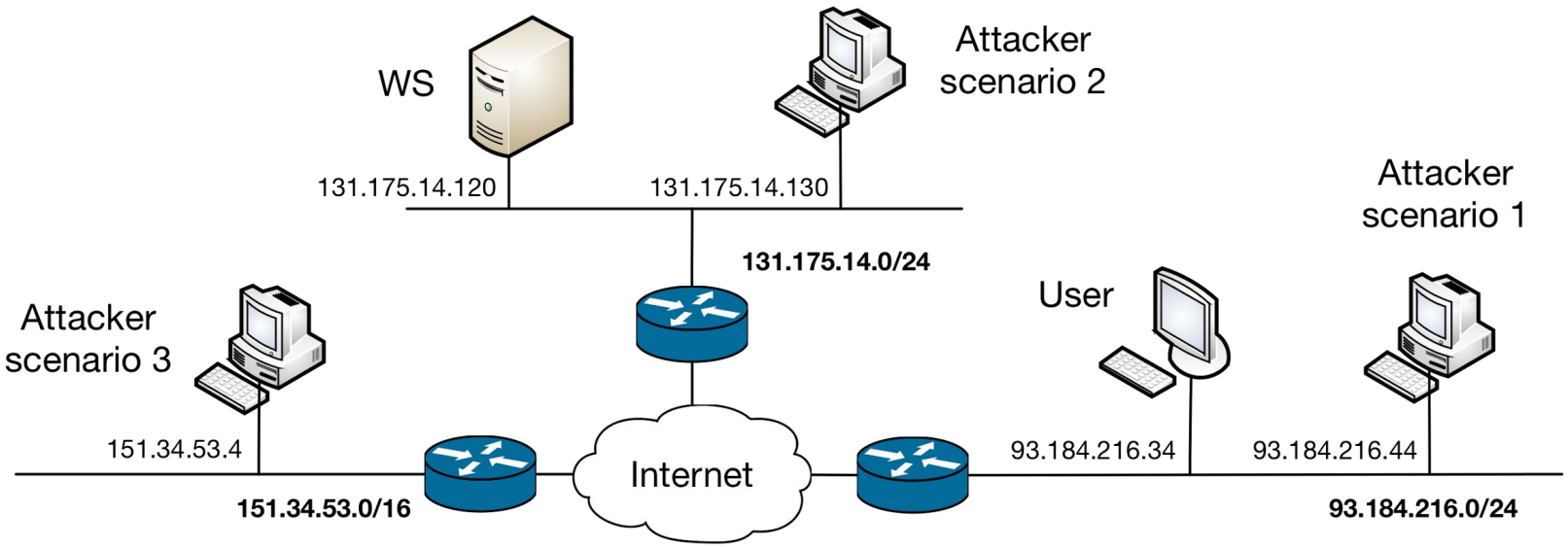
The goal is to saturate the resources of the victim using other machines on the network as an amplification mean. This results in a denial of service.

3. [1 point] Can you tell the IP and MAC address of the attacker? Why?

3. [1 point] Can you tell the IP and MAC address of the attacker? Why?

No, the IP address is spoofed for sure, and the MAC address can be spoofed as well.

Consider the following network diagram:



A user, with IP address 93.184.216.34, is attempting to download a software executable from a webserver in the Politecnico di Milano network, http://downloads.polimi.it, with IP address 131.175.14.120, over the HTTP protocol (no HTTPS, no signatures, nothing). Assume that the user's browser already cached the IP address of downloads.polimi.it (i.e., it does not perform any DNS request), and that there is no firewall involved. An attacker, who knows that the user is about to download this software, wants to target our user by carrying out an attack to replace the downloaded software with a piece of malware.

For each of the following attack scenarios, state whether the attacker is able to fulfill his\her goals. If you deem it possible, describe an attack that allows to do so: state the name of the class of attacks, and describe all the steps needed to make it work in this specific scenarios. If multiple classes of attacks are possible, focus on the simplest one that gets the job done. If no attack is possible, please explain why.

Scenario 1 (attacker: 93.184.216.44; same network and broadcast domain of the user):
Scenario 2 (attacker: 131.175.14.130; same network of web server, but different than user):
Scenario 3 (attacker: 151.34.53.4; attacker, user and webserver on three different networks):

For each of the following attack scenarios, state whether the attacker is able to fulfill his\her goals. If you deem it possible, describe an attack that allows to do so: state the name of the class of attacks, and describe all the steps needed to make it work in this specific scenarios. If multiple classes of attacks are possible, focus on the simplest one that gets the job done. If no attack is possible, please explain why.

Scenario 1 (attacker: 93.184.216.44; same network and broadcast domain of the user):

ARP spoofing ...

Scenario 2 (attacker: 131.175.14.130; same network of web server, but different than user):

Scenario 3 (attacker: 151.34.53.4; attacker, user and webserver on three different networks):

For each of the following attack scenarios, state whether the attacker is able to fulfill his\her goals. If you deem it possible, describe an attack that allows to do so: state the name of the class of attacks, and describe all the steps needed to make it work in this specific scenarios. If multiple classes of attacks are possible, focus on the simplest one that gets the job done. If no attack is possible, please explain why.

Scenario 1 (attacker: 93.184.216.44; same network and broadcast domain of the user):

ARP spoofing ...

Scenario 2 (attacker: 131.175.14.130; same network of web server, but different than user):

ARP spoofing ... (same as before but this time target the server)

Scenario 3 (attacker: 151.34.53.4; attacker, user and webserver on three different networks):

For each of the following attack scenarios, state whether the attacker is able to fulfill his\her goals. If you deem it possible, describe an attack that allows to do so: state the name of the class of attacks, and describe all the steps needed to make it work in this specific scenarios. If multiple classes of attacks are possible, focus on the simplest one that gets the job done. If no attack is possible, please explain why.

Scenario 1 (attacker: 93.184.216.44; same network and broadcast domain of the user):

ARP spoofing ...

Scenario 2 (attacker: 131.175.14.130; same network of web server, but different than user):

ARP spoofing ... (same as before but this time target the server)

Scenario 3 (attacker: 151.34.53.4; attacker, user and webserver on three different networks):

No attack possible, because HTTP uses TCP and, if sequence numbers are correctly implemented, not possible to perform TCP hijacking. Also, DNS poisoning not possible as DNS response already cached.

For the next questions <u>consider ONLY scenario 3</u>. Assume that each involved computer and server implements a custom TCP/IP stack that, for performance reasons, sets the TCP initial sequence number in the SYN and SYN+ACK packets as <u>the most significant bits of the current timestamp</u>.

2. [2 points]. Describe the security issue with the proposed ISN implementation, and propose a way to solve the issue

For the next questions <u>consider ONLY scenario 3</u>. Assume that each involved computer and server implements a custom TCP/IP stack that, for performance reasons, sets the TCP initial sequence number in the SYN and SYN+ACK packets as <u>the most significant bits of the current timestamp</u>.

2. [2 points]. Describe the security issue with the proposed ISN implementation, and propose a way to solve the issue

Can predict ISN -> solve by using random ISN

For the next questions <u>consider ONLY scenario 3</u>. Assume that each involved computer and server implements a custom TCP/IP stack that, for performance reasons, sets the TCP initial sequence number in the SYN and SYN+ACK packets as <u>the most significant bits of the current timestamp</u>.

3. [2 points]. Describe how the attacker can perform the above attack, this time *exploiting the security issues raised by the custom ISN implementation*. Describe all the steps and assumptions that you need to perform this attack.

For the next questions <u>consider ONLY scenario 3</u>. Assume that each involved computer and server implements a custom TCP/IP stack that, for performance reasons, sets the TCP initial sequence number in the SYN and SYN+ACK packets as <u>the most significant bits of the current timestamp</u>.

3. [2 points]. Describe how the attacker can perform the above attack, this time *exploiting the security issues raised by the custom ISN implementation*. Describe all the steps and assumptions that you need to perform this attack.

TCP hijacking. We can guess the ISN of the SYN packet sent by the victim (the user), we can spoof the webserver IP and send a "correct" SYN+ACK to it and, if we can guess the content of the request (we do), subsequent packets. This way we can send a different payload. In parallel we can also use TCP hijacking to send a fake RST to the actual server spoofing the user's IP address.
Problem\assumption: we need to know the ephemeral port used by the client to initiate the connection.

For the next questions <u>consider ONLY scenario 3</u>. Assume that each involved computer and server implements a custom TCP/IP stack that, for performance reasons, sets the TCP initial sequence number in the SYN and SYN+ACK packets as <u>the most significant bits of the current timestamp</u>.

4. [1 points]. Assume you are the network security administrator of the network of the attacker (<u>in the scenario 3</u> and assuming the custom TCP initial sequence number implementation), and that you control the border router between the network 151.34.53.0/24 and the rest of the Internet. Propose a way to prevent the attack. Can the administrator of the other two border routers in the diagram deploy the same mitigation, and obtain the same result? Why?

For the next questions <u>consider ONLY scenario 3</u>. Assume that each involved computer and server implements a custom TCP/IP stack that, for performance reasons, sets the TCP initial sequence number in the SYN and SYN+ACK packets as <u>the most significant bits of the current timestamp</u>.

4. [1 points]. Assume you are the network security administrator of the network of the attacker (<u>in the scenario 3</u> and assuming the custom TCP initial sequence number implementation), and that you control the border router between the network 151.34.53.0/24 and the rest of the Internet. Propose a way to prevent the attack. Can the administrator of the other two border routers in the diagram deploy the same mitigation, and obtain the same result? Why?

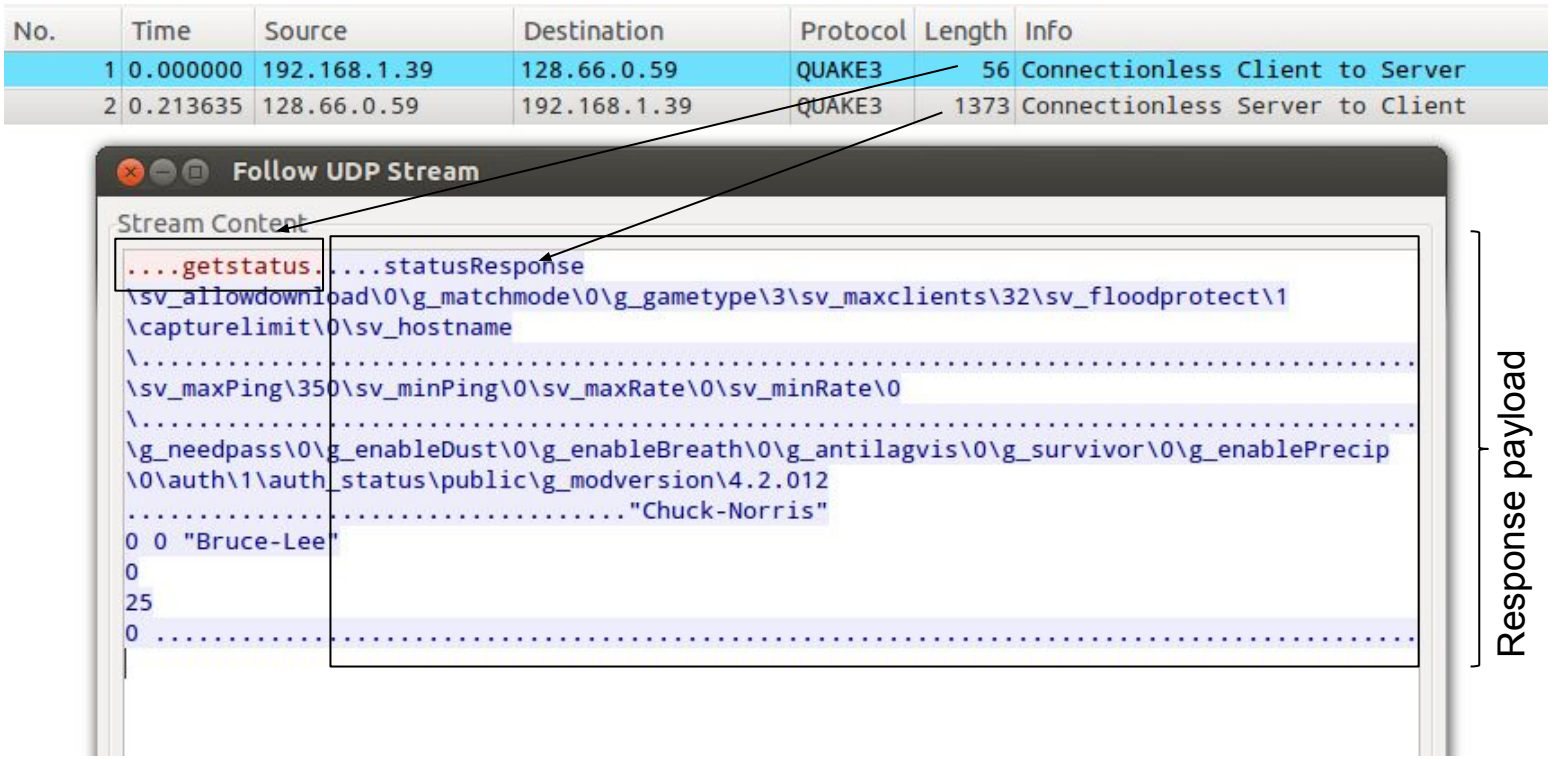
We can filter the packets with source IPs not belonging to our network. Other routers can't do this, they can only filter out packets coming from "outside" with spoofed IPs belonging to their network, but it's of little use in this scenario.

Question

Consider the “Quake III Arena Network Protocol”, a stateless client-server protocol used by the classic multi-player game. Quake III supports multiple game servers (indeed, anyone can run their server, expose it to the whole Internet, and even have it indexed by the “master server” for easy discovery).

When a client connects to one of the many available servers, it needs to retrieve some information. To this purpose, the Quake III protocol implements the command “`gestatus`”, accessible without authentication. When the server receives this command (via an UDP packet, destination port 27960), it replies with various information, such as: the list of enabled options, the hostname, the number of connected clients, and the type of supported game.

The image below is an example of protocol exchange, as shown in Wireshark, a packet capture tool: a client (192.168.1.39) sends a `getstatus` message to a server (128.66.0.59); the server replies with a `statusResponse` message, containing the information about the server in its payload.



2. [2 points] The part of the Quake III Arena protocol described in the previous page can be “misused” to *ease* a DoS attack against a victim. Please explain how an attack can misuse this protocol for this purpose, showing a concrete scenario where an attacker (who controls the server with IP address 93.184.216.32) aims to launch a DoS against the IP address 131.175.14.19. Make sure you mention in your answer the “feature” of this protocol that allows the misuse for DoS purpose.

2. [2 points] The part of the Quake III Arena protocol described in the previous page can be "misused" to *ease* a DoS attack against a victim. Please explain how an attack can misuse this protocol for this purpose, showing a concrete scenario where an attacker (who controls the server with IP address 93.184.216.32) aims to launch a DoS against the IP address 131.175.14.19. Make sure you mention in your answer the "feature" of this protocol that allows the misuse for DoS purpose.

The protocol allows an amplification-based denial of service: in fact, it is a UDP-based protocol, where a request of length 56 triggers a response of 1373 (in the example above), leading to a bandwidth amplification factor (BAF) of 24, i.e., "amplifying" the attacker's bandwidth of a factor of 24 (which means that, extremely roughly, if the attacker has a 100 Mbps network, given enough open Quake III servers with enough bandwidth each, it can flood the victim with a 2400 Mbps traffic).

*Concretely, the attacker (given he\she is in a network that allows IP spoofing) looks on the Internet for N open Quake III servers. It spoofs the victim's IP address, and sends to such servers M UDP "getstatus" packets. Each server will reply, for each packet received, with with the (long) information packet --- but, as the source IP is spoofed, the M * N packets will go to the victim, instead of the attacker.*

We discovered in the wild a DoS attack that exploits this protocol. The network administrators of the company that was hit by this attack were able to capture the following headers of some suspect packets at their network's border firewall:

```
IP 87.98.244.20 (src port 27960) > 104.28.1.1 (dst port 12345) UDP, length 1373
IP 87.98.244.20 (src port 27960) > 104.28.1.1 (dst port 12345) UDP, length 1373
IP 188.138.125.254 (src port 27960) > 104.28.1.1 (dst port 32451) UDP, length 1400
IP 188.138.125.254 (src port 27960) > 104.28.1.1 (dst port 32451) UDP, length 1400
IP 188.138.125.254 (src port 27960) > 104.28.1.1 (dst port 32451) UDP, length 1400
IP 188.138.125.254 (src port 27960) > 104.28.1.1 (dst port 32451) UDP, length 1400
IP 188.138.125.254 (src port 27960) > 104.28.1.1 (dst port 32451) UDP, length 1400
IP 5.196.85.159 (src port 27960) > 104.28.1.1 (dst port 32451) UDP, length 978
```

3. [1 point] Can you identify the attacker's IP address? And the victim's one? Why?

3. [1 point] Can you identify the attacker's IP address? And the victim's one? Why?

<u>Attacker</u>: no, the IP address you see in the logs are the ones of the vulnerable Quake III servers, not of the victim. Also, the vulnerable Quake servers can't identify the attacker's IP address as they're spoofed with the victim's IP.

<u>Victim</u>: yes, it's 104.28.1.1 (actually it could also be the border firewall or, in general, the company's network)

4. [1 point] As the network security administrator for the network hit by this attack (i.e., you control the border firewall and can add arbitrary rules), can you mitigate the effect of this attack or prevent it altogether? Why?

4. [1 point] As the network security administrator for the network hit by this attack (i.e., you control the border firewall and can add arbitrary rules), can you mitigate the effect of this attack or prevent it altogether? Why?

No. Due of the amplifying properties of the protocol, if the attacker has enough bandwidth that, amplified by the 24x factor of the protocol, is >= the victim's bandwidth, the attacker always succeeds.

However, if in this specific scenario the victim is the specific machine 104.28.1.1 and the bottleneck is not given by the network bandwidth of the Internet → company link, but from something else (e.g., the bandwidth of an internal network link, the capabilities of the machine itself, the capabilities of some network middlebox, …) implementing a firewall rule to drop UDP packet from source port 27960 can mitigate the attack (and thus it would be a good idea to implement).

In general, though, a more powerful DoS attack may be launched to defeat this mitigation…

5. [1 point] Consider the following mitigation implemented by the Quake III Arena server: "*when an IP address sends a* `getstatus` *command, the server will check if sender IP address has exceeded a pre-defined rate limit of 10 commands in a period of one second; if the rate limit is exceeded, the IP address is banned from the server forever*".

Is this solution effective to mitigate the impact of the DoS scenario in the above attack? Why?

5. [1 point] Consider the following mitigation implemented by the Quake III Arena server: "*when an IP address sends a* `getstatus` *command, the server will check if sender IP address has exceeded a pre-defined rate limit of 10 commands in a period of one second; if the rate limit is exceeded, the IP address is banned from the server forever*".
Is this solution effective to mitigate the impact of the DoS scenario in the above attack? Why?

No. While this mitigation restricts an attacker to exploit a vulnerable server as an amplifier at most 10 packets per second (i.e., 13730 bytes/s, i.e., about 100 kbps), given that enough vulnerable servers are available the attacker can just use multiple vulnerable Quake III servers at once to defeat the rate limit.

Moreover, if the attacker is targeting a network and not a specific IP address, it can spoof multiple IP of the same network, defeating the rate limiting.

6. [1 point] As the author(s) of Quake III Arena, you want to change the protocol to remove completely the issue that allows it from being exploited for DoS attacks. How would you <u>change the protocol</u> to achieve this goal?

6. [1 point] As the author(s) of Quake III Arena, you want to change the protocol to remove completely the issue that allows it from being exploited for DoS attacks. How would you <u>change the protocol</u> to achieve this goal?

<u>Solution 1</u>: Implement an handshake at the UDP protocol level (making sure it does not have amplifying capabilities). E.g., the client sends getinfo, the server responds with a nonce, and the client sends the nonce back to the server, then the server sends the "long" information message.

<u>Solution 2</u>: Move the protocol to TCP instead of UDP as a transport protocol. Due to the three-way handshake, TCP is immune to the amplification issue.

The End